

REQUEST FOR PROPOSAL & STATEMENT OF WORK

Real-Time Fraud Detection System — PaySecure Financial

Client: PaySecure Financial | **Vendor:** FraudGuard AI | **Budget:** \$680,000 | **Duration:** 10 months | **Start:** 2026-08-01

1. Project Overview & Goals

PaySecure requires a real-time fraud detection system processing 50,000 transactions per second with sub-50ms decision latency, integrating with payment rails (ISO 20022), and providing case management for fraud analysts. PCI-DSS Level 1 compliance is mandatory.

Goals: (1) Fraud detection rate $\geq 95\%$ on card-not-present fraud. (2) False positive rate $<0.5\%$ to minimise customer friction. (3) Decision latency $<50\text{ms}$ at p99. (4) Analyst case resolution time reduced by 30%.

2. Scope of Work & MVP

MVP (Month 1–4): Rule-based fraud engine for top-5 fraud patterns, transaction scoring API, and basic analyst dashboard. MVP complete when system processes 1,000 TPS with $<50\text{ms}$ latency and detects all 5 synthetic fraud scenarios in UAT.

Out of Scope: AML (anti-money laundering) compliance beyond defined rules; voice/biometric authentication; cross-border FX fraud.

3. Work Breakdown & Timelines

ID	Work Item	Timeline	Entry Criteria	Definition of Done / Exit Criteria
WI-001	Real-Time Transaction Scoring Engine	Month 1–3	Data schema agreed; Kafka cluster provisioned	Processed 50k TPS; p99 latency $<50\text{ms}$; circuit breaker active
WI-002	ML Fraud Model (Gradient Boosting)	Month 2–5	WI-001 done; 24-month labelled data acquired	Fraud detection $\geq 95\%$; FPR $<0.5\%$ on holdout; model card with fa
WI-003	Case Management & Analyst Tooling	Month 4–7	WI-001 done; analyst workflow documented	Case management console created for flagged transactions; analyst SLA dash
WI-004	ISO 20022 Integration	Month 5–8	WI-001 done; payment rail API keys obtained	All ISO 20022 message types parsed; enrichment from payme
WI-005	Model Monitoring & Champion-Challenger	Month 7–10	WI-002 deployed; monitoring agreed	PSI alerts for feature drift; champion-challenger framework live

4. Legal & Contractual Obligations

4.1 Late Delivery Penalty: \$20,000 per calendar day after a 10-day grace period per milestone. No cap on cumulative penalties for Tier-1 milestones (WI-001, WI-002). Penalty for non-Tier-1 milestones capped at \$100,000 each.

4.2 Subcontracting: Up to 20% of total effort may be subcontracted with 14-day written notice. Subcontractors must be disclosed by name, role, and access level. Any subcontractor with cardholder data access requires PCI-DSS compliant background check.

4.3 Indemnity: Mutual indemnity for respective breaches. Vendor indemnifies Client for fraud losses directly attributable to a system outage caused by Vendor's code during business hours (SLA: 99.99% uptime). Liability cap for such losses: \$5M.

4.4 Intellectual Property: Mutual IP: Client owns all trained models and Client-specific feature engineering; Vendor retains fraud detection framework and generic ML components. Joint ownership of novel detection algorithms developed under this engagement; each party may license independently.

4.5 Insurance: Cyber Liability $\geq$ \$20M (PCI mandate); Professional Indemnity $\geq$ \$5M; Financial Institution Bond $\geq$ \$10M; errors and omissions covering AI decision-making.

5. Security Requirements

5.1 SAST: All code (Java/Python) scanned with Checkmarx at every PR merge. OWASP Top 10 compliance verified at each release gate. Dependency vulnerability scanning via OWASP Dependency-Check.

5.2 VAPT: Quarterly penetration tests during development; bi-annual post go-live. Scope: transaction API, case management portal, Kafka cluster, ML model endpoints. Scoping must include business logic testing for fraud bypass.

5.3 PCI-DSS: All cardholder data tokenised before storage. Encryption key management per PCI HSM standard. Network segmentation between fraud engine and cardholder data environment. ASV scans quarterly; QSA AOC required at go-live.

6. Project Closure

Closure: (1) Live fraud detection rate $\geq$ 93% for 30 days in production. (2) FPR $< 0.5\%$ maintained. (3) PCI-DSS Level 1 AOC delivered. (4) All VAPT criticals resolved. (5) Analyst productivity improvement of $\geq 25\%$ demonstrated. (6) Champion-challenger framework operational. (7) 60-day hypercare with fraud analyst support included.